10. Settings, login and security

Login (`/login`)

Role-based accounts (admin / operator). Passwords are never stored in plain text.

Settings (`/settings`)

Read-only view of backend status, crawler limits, OCR engine and policies. Admins also see the tamper-evident audit trail. Local file paths are not exposed.

Security controls

- Allow-list of domains; SSRF protection (private and internal addresses refused, redirects re-validated, DNS pinned).
- robots.txt respected; no access-control bypass.
- Live scanning is off unless `ENABLE_LIVE_SCAN=true` .
- Never clicks CAPTCHAs, never submits forms, never harvests tokens.